

CDS-308-MJP Web and Network Security Fundamentals

Exam-Ready Practical Answer Sheet - 15 Marks Each

Q1 and Q2 of all 25 sheets | Simple language | Step-by-step report format

Important: In the practical exam, replace blank fields (_____) with the actual values from your lab system, scan or packet capture. Do not invent IPs, ports, scan findings or results.

SHEET 1

Q1. Configure a small network with two or more systems and assign appropriate IP addresses. Verify the configuration. [15M]

Aim: To configure a small LAN with two or more computers, assign IP addresses in the same subnet, and verify the configuration.

Tools/Requirements: Two computers/VMs, Ethernet/Wi-Fi/virtual network, Windows or Linux, Command Prompt/Terminal

Step-by-Step Procedure

1. Connect both systems to the same switch, Wi-Fi, or virtual network.
2. Choose a private IPv4 network. Example: 192.168.10.0/24.
3. Assign System A: IP 192.168.10.10, Subnet Mask 255.255.255.0.
4. Assign System B: IP 192.168.10.20, Subnet Mask 255.255.255.0.
5. If Internet access is required, enter the correct default gateway and DNS supplied by the lab. Otherwise they may be left blank for a two-system LAN.
6. On Windows, open Network Adapter Properties > IPv4 and enter the values. On Linux, use Network Settings or the lab's network manager.
7. Verify System A using `ipconfig` on Windows or `ip addr` on Linux.
8. Verify System B in the same way.
9. Check that the network ID is the same on both systems and that no duplicate IP address is used.
10. Finally test connectivity using ping between the two IP addresses.

What to Observe / Explain

- Record hostname, IPv4 address, subnet mask/prefix, gateway and DNS for each system.
- Both systems should show addresses from the same subnet, e.g. 192.168.10.x/24.
- A successful ping confirms basic Layer-3 connectivity.

Report Format

Item	Record in Exam
System A IP	_____
System B IP	_____
Subnet mask	_____
Gateway	_____
Verification command	ipconfig / ip addr
Connectivity	Successful / Failed

Result/Conclusion: The small LAN was configured successfully. Appropriate IP addresses were assigned and verified, and connectivity between the systems was confirmed.

Q2. Use the ping command to test connectivity between two systems and explain the results. [15M]

Aim: To test connectivity between two systems using the ping command and interpret the output.

Tools/Requirements: Two configured systems, Command Prompt/Terminal

Step-by-Step Procedure

1. Find the destination system's IP address.
2. Open Command Prompt or Terminal on the source system.
3. Run `ping 192.168.10.20` on Windows or `ping -c 4 192.168.10.20` on Linux.
4. Observe the Echo Request and Echo Reply messages.
5. Record the number of packets sent, received and lost.
6. Record round-trip time values such as minimum, maximum and average delay.
7. If replies are received, connectivity exists.
8. If `Request timed out` appears, check firewall, cabling, Wi-Fi, IP address and subnet.
9. If `Destination host unreachable` appears, the route or local network configuration may be incorrect.
10. Repeat the test in the reverse direction if required.

What to Observe / Explain

- Reply from <IP>: indicates successful ICMP communication.
- 0% packet loss generally means successful communication.
- High latency or packet loss can indicate congestion, weak wireless signal, filtering or network problems.

Report Format

Item	Record in Exam
Source IP	_____
Destination IP	_____
Packets sent	4
Packets received	_____
Packet loss	_____ %
Average RTT	_____ ms
Result	Reachable / Not reachable

Result/Conclusion: Ping was used to verify connectivity. The result was interpreted using replies, packet loss and round-trip time.

SHEET 2

Q1. Use traceroute/tracert to identify the path followed by packets to a destination. [15M]

Aim: To identify the route followed by packets from the local system to a destination using traceroute/tracert.

Tools/Requirements: Internet/LAN connection, Windows `tracert` or Linux `traceroute`

Step-by-Step Procedure

1. Open Command Prompt or Terminal.
2. Select an authorized/reachable destination such as the lab gateway or a permitted public host.
3. On Windows run `tracert <destination>`.
4. On Linux run `traceroute <destination>`.
5. Observe each hop number displayed in order.
6. For each hop, note the router IP/hostname and response times.
7. An asterisk `\*` can mean that a router did not return the expected ICMP response or that filtering occurred.
8. The last hop should normally be the destination if it responds.
9. Count the number of hops and compare delay values.
10. Save a screenshot or copy the command output for the report.

What to Observe / Explain

- Hop number represents a routing device crossed by the packet.
- Three time values normally represent three probe packets.
- The route can change because of routing policies, load balancing or ISP design.

Report Format

Item	Record in Exam
Destination	_____
Total hops	_____
First hop/gateway	_____
Final hop	_____
Highest observed delay	_____ ms
Result	Route identified

Result/Conclusion: Traceroute/tracert displayed the intermediate hops between source and destination and helped identify the network path.

Q2. Configure a basic LAN and troubleshoot a connectivity problem caused by an incorrect IP address or subnet mask. [15M]

Aim: To configure a basic LAN and troubleshoot a connectivity failure caused by an incorrect IP address or subnet mask.

Tools/Requirements: Two systems, LAN/virtual network, ipconfig/ip addr, ping

Step-by-Step Procedure

1. Configure two systems on the same LAN with valid addresses, for example 192.168.10.10/24 and 192.168.10.20/24.
2. Verify that ping works before creating the fault.
3. Introduce or identify the incorrect setting, for example System B = 192.168.20.20/24 or an incorrect subnet mask.
4. Run `ipconfig` or `ip addr` on both systems.
5. Compare the IP address and mask with the planned network.
6. Calculate/check whether both IPs belong to the same network.
7. Ping the destination and note the error.
8. Correct the wrong IP address or subnet mask.
9. Disable/enable the adapter or renew the configuration if required.
10. Ping again and record the successful result.

What to Observe / Explain

- Incorrect network ID causes local hosts to treat each other as remote or unreachable.
- Incorrect subnet mask can place hosts in different logical networks even when their addresses look similar.
- Troubleshooting should compare expected and actual values before changing settings.

Report Format

Item	Record in Exam
------	----------------

Expected network	_____
Incorrect setting found	_____
Ping before correction	Failed
Corrected IP/mask	_____
Ping after correction	Successful

Result/Conclusion: The connectivity issue was traced to an incorrect IP/subnet configuration. After correcting the configuration, communication was restored.

SHEET 3

Q1. Perform a basic Nmap scan on an authorized system and identify the active hosts. [15M]

Aim: To perform a basic Nmap host-discovery scan on an authorized lab network and identify active hosts.

Tools/Requirements: Kali/Linux/Windows with Nmap, Authorized lab subnet

Step-by-Step Procedure

1. Confirm the authorized subnet, e.g. 192.168.56.0/24.
2. Open a terminal.
3. Run ``nmap -sn 192.168.56.0/24``.
4. Nmap sends host-discovery probes without performing a normal port scan.
5. Wait for the scan to complete.
6. Look for lines such as ``Nmap scan report for ...`` followed by ``Host is up``.
7. Record each active IP address and hostname if resolved.
8. Record MAC address/vendor information if displayed on the local LAN.
9. Count the total hosts reported as up.
10. Save the terminal output for evidence.

What to Observe / Explain

- ``Host is up`` means Nmap received a response indicating the system is active.
- A host may be active but not discovered if probes are filtered, so results describe what Nmap observed, not absolute proof of absence.

Report Format

Item	Record in Exam
Authorized subnet	_____
Command	<code>nmap -sn _____</code>
Active host 1	_____
Active host 2	_____
Total active hosts	_____

Result/Conclusion: A basic Nmap discovery scan was completed on the authorized lab network and the responding active hosts were identified.

Q2. Scan an authorized host to identify open TCP ports and record the results. [15M]

Aim: To scan an authorized host for open TCP ports and record the results.

Tools/Requirements: Nmap, Authorized target IP

Step-by-Step Procedure

1. Obtain the authorized target IP address.
2. Verify that the target is reachable if required.
3. Run a basic scan: ``nmap <target-ip>``.
4. For a full TCP port check in the lab, use ``nmap -p- <target-ip>`` if instructed.
5. Observe the PORT, STATE and SERVICE columns.
6. Record each port reported as ``open``.
7. Note that ``closed`` means the host responded but no service is listening, while ``filtered`` means Nmap could not determine the state because of filtering.
8. If needed, use ``nmap -sV <target-ip>`` only to identify service versions in the authorized lab.
9. Save the scan output using ``-oN scan.txt`` if required.
10. Prepare a table of findings.

What to Observe / Explain

- Open ports represent listening network services and should be justified by system requirements.
- Common examples: 22/SSH, 80/HTTP, 443/HTTPS, 53/DNS.

Report Format

Item	Record in Exam
Target IP	_____
Port	_____
Protocol	TCP
State	Open/Closed/Filtered
Service	_____

Total open TCP ports	_____
----------------------	-------

Result/Conclusion: The authorized host was scanned and its open TCP ports were recorded for further security review.

SHEET 4

Q1. Identify the services running on open ports using appropriate Nmap options. [15M]

Aim: To identify services and versions running on open ports using Nmap service detection.

Tools/Requirements: Nmap, Authorized host

Step-by-Step Procedure

1. Run a basic scan first: ``nmap <target-ip>``.
2. Run service/version detection: ``nmap -sV <target-ip>``.
3. Nmap probes open ports and attempts to identify the application/service.
4. Read the PORT, STATE, SERVICE and VERSION columns.
5. Record service names such as ssh, http, https, ftp or smtp.
6. Record version information only as reported by Nmap.
7. Do not assume a service is vulnerable only because a version is shown.
8. If the service is unknown, record it as ``unknown`` rather than guessing.
9. Save the output or screenshot for the report.
10. Compare the identified service with the expected purpose of the host.

What to Observe / Explain

- Service detection provides more detail than a simple port scan.
- Version information can support patch and exposure review.

Report Format

Item	Record in Exam
Port	_____
State	_____
Service	_____
Version	_____
Expected service?	Yes/No

Result/Conclusion: Nmap service/version detection identified the services listening on the authorized host's open ports.

Q2. Compare the results of a basic Nmap scan and a service/version detection scan. [15M]

Aim: To compare a basic Nmap scan with a service/version detection scan.

Tools/Requirements: Nmap, Authorized host

Step-by-Step Procedure

1. Run ``nmap <target-ip>`` and save the output.
2. Run ``nmap -sV <target-ip>`` and save the output.
3. Compare the number of open ports in both results.
4. Observe that the basic scan usually reports port number, state and a likely service name based mainly on the port.
5. Observe that ``-sV`` actively probes the service and tries to identify the product/version.
6. Compare scan duration; version detection usually takes longer.
7. Check whether any service names differ after probing.
8. Prepare a comparison table.
9. Mention that version results can be incomplete or hidden by banners/proxies.
10. Conclude which scan gives more detail and why.

What to Observe / Explain

- Basic scan = faster, less detailed.
- Service/version scan = more informative for security assessment but generates more probes.

Report Format

Item	Record in Exam
Feature	Basic scan: <code>nmap target</code> Version scan: <code>nmap -sV target</code>
Open ports	Shown in both
Service name	Basic/likely Probed
Version	Usually not shown Often shown
Time	Lower Higher

Result/Conclusion: Both scans identify open ports, but `-sV` gives additional service and version information useful for security assessment.

SHEET 5

Q1. Analyze an Nmap scan result and prepare a table containing port number, protocol, state, and detected service. [15M]

Aim: To analyze an Nmap result and prepare a structured table of ports, protocols, states and services.

Tools/Requirements: Existing Nmap output or authorized Nmap scan

Step-by-Step Procedure

1. Open the provided Nmap result or perform the instructed authorized scan.
2. Locate the main results table.
3. Read each port in `port/protocol` format, e.g. 80/tcp.
4. Record the state: open, closed or filtered.
5. Record the detected service name.
6. If version information is present, keep it as an optional note.
7. Do not add ports that are not present in the actual output.
8. Count the open ports.
9. Highlight services that are unexpected for the target's role.
10. Prepare the final table neatly in the answer sheet.

What to Observe / Explain

- The table should reflect the exact Nmap result.
- Unexpected open services should be reviewed, but an open port alone does not prove a vulnerability.

Report Format

Item	Record in Exam
Port	Protocol / State / Service
_____	_____ / _____ / _____
_____	_____ / _____ / _____
_____	_____ / _____ / _____

Result/Conclusion: The Nmap output was converted into a clear table showing port number, protocol, state and detected service.

Q2. Capture network traffic using Wireshark and identify different protocols present in the capture. [15M]

Aim: To capture network traffic using Wireshark and identify different protocols in the capture.

Tools/Requirements: Wireshark, Active network interface

Step-by-Step Procedure

1. Open Wireshark with permission to capture traffic.
2. Select the active Ethernet/Wi-Fi/virtual adapter.
3. Start packet capture.
4. Generate normal traffic such as ping, DNS lookup and visiting an authorized HTTP/HTTPS site.
5. Stop the capture after enough packets are collected.
6. Use the Protocol column to identify protocols.
7. Apply display filters such as `arp`, `icmp`, `dns`, `tcp`, `udp`, `http` or `tls`.
8. Select sample packets and inspect the packet details pane.
9. Record at least three protocols and their purpose.
10. Save the capture as a `.pcapng` file if required.

What to Observe / Explain

- ARP resolves local IPv4 addresses to MAC addresses.
- ICMP carries diagnostic messages such as ping.
- DNS resolves names to IP addresses.
- TCP/UDP transport application traffic; HTTP/TLS may appear above them.

Report Format

Item	Record in Exam
Protocol 1	_____ - purpose: _____
Protocol 2	_____ - purpose: _____
Protocol 3	_____ - purpose: _____
Capture interface	_____

Result/Conclusion: Wireshark successfully captured network traffic and multiple protocols were identified and explained.

SHEET 6

Q1. Apply a Wireshark filter to display only ICMP packets and analyze a ping communication. [15M]

Aim: To filter ICMP traffic in Wireshark and analyze a ping request/reply exchange.

Tools/Requirements: Wireshark, ping command

Step-by-Step Procedure

1. Start Wireshark on the active interface.
2. Start capture.
3. From another terminal run `ping <destination-ip>`.
4. Return to Wireshark and stop capture.
5. Enter the display filter `icmp`.
6. Locate an `Echo (ping) request` packet.
7. Record its source IP, destination IP, ICMP type and sequence number.
8. Locate the corresponding `Echo (ping) reply` packet.
9. Confirm that the source/destination addresses are reversed.
10. Compare request and reply identifiers/sequence values and note successful communication.

What to Observe / Explain

- ICMP Echo Request is commonly Type 8; Echo Reply is Type 0 for IPv4.
- Matching request/reply packets prove that the remote system responded to the ping.

Report Format

Item	Record in Exam
Request source	_____
Request destination	_____
Request type	Echo Request
Reply source	_____
Reply destination	_____
Result	Reply received / No reply

Result/Conclusion: The ICMP filter isolated ping traffic, and the Echo Request and Echo Reply packets were identified successfully.

Q2. Capture DNS traffic and identify the source, destination, query, and response information. [15M]

Aim: To capture DNS traffic and identify source, destination, query and response information.

Tools/Requirements: Wireshark, Browser or nslookup/dig

Step-by-Step Procedure

1. Start a Wireshark capture on the active interface.
2. Generate a DNS lookup, e.g. `nslookup example.com` or an approved domain.
3. Stop the capture.
4. Apply the display filter `dns`.
5. Select a DNS query packet.
6. Record source IP, destination IP (DNS server), transaction ID, query name and query type such as A or AAAA.
7. Find the matching DNS response using the transaction ID.
8. Record the returned IP address(es), response code and TTL if visible.
9. Confirm that the response source is the DNS server and destination is the client.
10. Prepare a query/response table.

What to Observe / Explain

- A DNS query asks the resolver for a record; the response supplies an answer or an error such as NXDOMAIN.
- UDP port 53 is common for standard DNS, though DNS can also use TCP and encrypted variants.

Report Format

Item	Record in Exam
Client/source IP	_____
DNS server IP	_____
Query name	_____
Query type	A/AAAA/Other

Answer IP	_____
Response code	_____

Result/Conclusion: DNS query and response packets were captured and their main fields were identified.

SHEET 7

Q1. Analyze an HTTP packet capture and identify important fields such as source IP, destination IP, method, and response status. [15M]

Aim: To analyze an HTTP packet capture and identify source IP, destination IP, HTTP method and response status.

Tools/Requirements: Wireshark, Authorized HTTP test traffic/pcap

Step-by-Step Procedure

1. Open the provided capture or capture authorized HTTP traffic.
2. Apply display filter `http`.
3. Locate an HTTP request packet.
4. Record source and destination IP addresses from the IP header.
5. In the HTTP section, record the request method such as GET or POST.
6. Record the Host header and requested URI/path if visible.
7. Locate the corresponding HTTP response.
8. Record the status code such as 200, 301, 404 or 500.
9. Record server/content-type headers if required.
10. Explain the meaning of the observed method and status.

What to Observe / Explain

- HTTP is clear-text; HTTPS payload is normally encrypted and appears mainly as TLS unless decrypted in an authorized lab.
- Status 200 = success, 404 = not found, 500 = server error.

Report Format

Item	Record in Exam
Source IP	_____
Destination IP	_____
Method	GET/POST/...
Host/URI	_____
Response status	_____
Meaning	_____

Result/Conclusion: The HTTP request and response were analyzed and the required addressing, method and status fields were recorded.

Q2. Examine a packet capture and identify traffic that appears unusual or suspicious. Give reasons for your observation. [15M]

Aim: To inspect a packet capture for traffic that appears unusual or suspicious and justify the observation using evidence.

Tools/Requirements: Wireshark, Provided or lab capture

Step-by-Step Procedure

1. Open the capture and first identify the normal baseline protocols and communicating hosts.
2. Use Statistics > Protocol Hierarchy and Endpoints/Conversations to find dominant traffic.
3. Look for repeated connection attempts to many ports or hosts.
4. Look for unusually high packet rates, repeated failed TCP SYN attempts, unexpected DNS requests or communication with unknown external IPs.
5. Check for clear-text credentials/data only if present in the authorized capture; do not assume.
6. Use filters such as `tcp.flags.syn==1 && tcp.flags.ack==0`, `dns`, `icmp`, or a specific `ip.addr==x.x.x.x` to verify the pattern.
7. Inspect timestamps, source/destination, ports and frequency.
8. Compare the activity with the expected role of the system.
9. Record concrete packet numbers as evidence.
10. Classify the observation as normal, unusual or suspicious rather than declaring malware without proof.

What to Observe / Explain

- Suspicion should be evidence-based: unusual frequency, destination, port, protocol or repeated failures.
- One unusual packet may have a legitimate explanation; context is important.

Report Format

Item	Record in Exam
Observed pattern	_____
Source	_____
Destination	_____
Protocol/port	_____
Packet numbers	_____
Reason it is unusual	_____

Result/Conclusion: Potentially unusual communication was identified from packet evidence and justified without making unsupported conclusions.

SHEET 8

Q1. Configure Burp Suite and a browser in an authorized lab environment to intercept HTTP requests. [15M]

Aim: To configure Burp Suite and a browser in an authorized lab so that HTTP requests can be intercepted.

Tools/Requirements: Burp Suite Community/Professional, Browser, Authorized lab web application

Step-by-Step Procedure

1. Open Burp Suite and create a temporary/project file as available.
2. Go to Proxy > Proxy settings and confirm a listener is active on 127.0.0.1:8080.
3. Configure the browser proxy to HTTP proxy 127.0.0.1, port 8080. A Burp-provided browser may already be configured.
4. Open Proxy > Intercept and switch interception ON.
5. Browse to the authorized HTTP test application.
6. Burp should pause the request in the Intercept tab.
7. Inspect the request line, Host header and other headers.
8. Click Forward to allow the request to continue.
9. For HTTPS in a lab, use Burp's browser or install Burp's CA certificate only in the dedicated test browser if instructed.
10. After the practical, restore the browser proxy setting.

What to Observe / Explain

- A correctly configured proxy sends browser traffic through Burp.
- Interception lets the analyst view requests before they are forwarded.

Report Format

Item	Record in Exam
Proxy IP	127.0.0.1
Proxy port	8080
Test URL	_____
Method seen	_____
Host header	_____
Intercept successful	Yes/No

Result/Conclusion: Burp Suite and the browser were configured successfully, and an authorized HTTP request was intercepted.

Q2. Capture a web application's GET request using Burp Suite and identify its important components. [15M]

Aim: To capture a web application's GET request in Burp Suite and identify its important components.

Tools/Requirements: Burp Suite, Authorized web application

Step-by-Step Procedure

1. Ensure the browser is routed through Burp and Intercept is ON.
2. Open a page or perform a search that generates a GET request.
3. Capture the request in Proxy > Intercept or select it from Proxy > HTTP history.
4. Identify the request line: `GET /path?parameter=value HTTP/1.1`.
5. Record the Host header.
6. Identify query-string parameters after `?` and separated by `&`.
7. Record relevant headers such as User-Agent, Accept, Referer and Cookie if present.
8. Note that GET parameters are present in the URL and are often logged/history-visible.
9. Forward the request and observe the response status in HTTP history.
10. Prepare a component table.

What to Observe / Explain

- Important parts: method, path/URL, protocol version, headers, cookies, query parameters.
- Sensitive data should generally not be placed in GET query strings.

Report Format

Item	Record in Exam
Method	GET
Path/URL	_____

Host	_____
Parameter(s)	_____
Cookie present	Yes/No
Response status	_____

Result/Conclusion: The GET request was captured and its main components were identified.

SHEET 9

Q1. Capture a POST request and identify the parameters and headers transmitted to the server. [15M]

Aim: To capture a POST request and identify the parameters and headers sent to the server.

Tools/Requirements: Burp Suite, Authorized lab web form

Step-by-Step Procedure

1. Configure the browser to use Burp and open the authorized test form.
2. Turn Intercept ON.
3. Enter harmless sample values and submit the form.
4. Capture the POST request.
5. Record the request line and target path.
6. Identify headers such as Host, Content-Type, Content-Length, Cookie, User-Agent and Referer if present.
7. Locate the request body.
8. Record parameter names and sample values from form-urlencoded, multipart or JSON content.
9. Forward the request and note the response status.
10. Do not submit destructive or unauthorized values; the purpose is observation only.

What to Observe / Explain

- POST usually carries submitted data in the request body rather than the URL.
- Content-Type tells the server how the body is encoded.

Report Format

Item	Record in Exam
Method	POST
Target path	_____
Content-Type	_____
Parameter names	_____
Important headers	_____
Response status	_____

Result/Conclusion: The POST request was captured and its body parameters and important headers were documented.

Q2. Use Nikto on an authorized test web application and identify the security-related findings reported by the tool. [15M]

Aim: To run Nikto against an authorized test web application and document the security-related findings.

Tools/Requirements: Nikto, Authorized lab web server

Step-by-Step Procedure

1. Confirm the authorized target URL/IP.
2. Open a terminal.
3. Run ``nikto -h http://<authorized-target>``.
4. If the lab uses a non-default port, use ``-p <port>``.
5. Allow the scan to complete.
6. Record server/banner information reported by Nikto.
7. Record security headers that are missing or misconfigured if Nikto reports them.
8. Record exposed files/directories, default content or outdated component notices exactly as shown.
9. Save output with ``-output nikto-report.txt`` if required.
10. Treat findings as leads that require verification; do not claim confirmed exploitation.

What to Observe / Explain

- Nikto is a web-server assessment scanner that checks many known server configuration and file issues.
- Results can include informational items and false positives.

Report Format

Item	Record in Exam
Target	_____
Server/technology	_____
Finding 1	_____
Finding 2	_____

Finding 3	
Recommended action	

Result/Conclusion: Nikto scanned the authorized web server and the reported security-related observations were documented.

SHEET 10

Q1. Analyze an intercepted web request and identify possible input-validation or security weaknesses without exploiting the system. [15M]

Aim: To review an intercepted web request and identify possible input-validation or security weaknesses without exploiting the application.

Tools/Requirements: Burp Suite, Authorized request

Step-by-Step Procedure

1. Capture a normal request from the authorized lab application.
2. Identify all user-controlled inputs: URL parameters, body parameters, cookies and selected headers.
3. Check whether expected input types are obvious, e.g. numeric ID, email, date or fixed choice.
4. Look for missing client/server validation indicators, excessive parameter length, unexpected characters accepted by the normal interface, or parameters that appear security-sensitive.
5. Check whether sensitive data appears in the URL, which can be stored in history/logs.
6. Check for missing anti-CSRF token on state-changing forms only as an observation; do not attempt exploitation.
7. Check whether authentication/session cookies include security attributes if visible.
8. Review whether redirects/paths are entirely user-controlled.
9. Document each weakness as `possible` unless verified by safe application behavior.
10. Recommend server-side allow-list validation, output encoding, parameterized queries, access control checks and secure cookie settings as appropriate.

What to Observe / Explain

- Input-validation review should be non-destructive.
- A suspicious parameter does not prove a vulnerability; evidence and safe verification are required.

Report Format

Item	Record in Exam
Input/parameter	_____
Expected format	_____
Observed concern	_____
Risk	Low/Medium/High
Recommended control	_____

Result/Conclusion: The intercepted request was reviewed for possible validation and security weaknesses without exploiting the system.

Q2. Configure basic firewall rules to allow required network traffic and block unnecessary traffic. [15M]

Aim: To configure basic firewall rules that allow required traffic and block unnecessary traffic.

Tools/Requirements: Host firewall: Windows Defender Firewall or Linux UFW, Authorized lab host

Step-by-Step Procedure

1. List the services that must remain available, e.g. SSH 22 or HTTP 80 in the lab.
2. List unnecessary ports/services that should be blocked.
3. On Linux UFW: check `sudo ufw status`.
4. Set a safe policy appropriate to the lab, for example `sudo ufw default deny incoming` and `sudo ufw default allow outgoing`.
5. Allow a required service, e.g. `sudo ufw allow 22/tcp`.
6. Block an unnecessary port, e.g. `sudo ufw deny 23/tcp`.
7. Enable the firewall using `sudo ufw enable` if the lab permits.
8. Verify rules with `sudo ufw status numbered`.
9. From another authorized host, test the allowed and blocked ports.
10. Record the rules and test results. On Windows, equivalent inbound rules can be created in Windows Defender Firewall with Advanced Security.

What to Observe / Explain

- Firewall rules should follow least privilege: allow only required inbound traffic.
- Test after configuration to avoid accidentally blocking required access.

Report Format

Item	Record in Exam
------	----------------

Required port/service	_____ / Allow
Blocked port/service	_____ / Deny
Firewall status	Active/On
Allowed test	Success/Fail
Blocked test	Blocked/Not blocked

Result/Conclusion: Basic firewall rules were configured and verified to permit required traffic while blocking unnecessary traffic.

SHEET 11

Q1. Create a password policy requiring minimum password length and complexity, and verify that it is applied. [15M]

Aim: To configure a password policy requiring minimum length and complexity and verify that the policy is applied.

Tools/Requirements: Windows Local Security Policy or equivalent Linux policy, Test user account

Step-by-Step Procedure

1. Open the local security policy tool. On Windows: `secpol.msc`.
2. Go to Account Policies > Password Policy.
3. Set a suitable minimum password length, e.g. 8 or more characters as instructed by the lab.
4. Enable `Password must meet complexity requirements`.
5. Optionally configure password history and maximum/minimum age if part of the lab policy.
6. Apply the policy.
7. Attempt to set a password that is too short or simple.
8. Confirm that the system rejects it.
9. Set a password that satisfies the configured policy.
10. Record the policy settings and verification result.

What to Observe / Explain

- Complexity policies commonly require a mixture of character categories and prevent use of the account name.
- Actual organization policy should follow its security standard; the lab value is only for demonstration.

Report Format

Item	Record in Exam
Minimum length	_____
Complexity	Enabled/Disabled
Weak password test	Rejected/Accepted
Compliant password test	Accepted/Rejected
Policy verified	Yes/No

Result/Conclusion: The password policy was configured and its enforcement was verified using test passwords.

Q2. Configure a system to restrict unnecessary network services and verify the changes. [15M]

Aim: To restrict unnecessary network services on a system and verify that the changes are effective.

Tools/Requirements: Windows Services / Linux systemctl, ss/netstat/Nmap

Step-by-Step Procedure

1. Identify listening services with `ss -tulnp` on Linux or `netstat -ano`/Resource Monitor on Windows.
2. List services required for the system's purpose.
3. Identify one or more unnecessary services in the lab.
4. On Linux, inspect a service with `systemctl status <service>`.
5. Stop the unnecessary service: `sudo systemctl stop <service>`.
6. Prevent automatic start if appropriate: `sudo systemctl disable <service>`.
7. On Windows, use Services (`services.msc`) to stop the unnecessary service and change its startup type as instructed.
8. Run the listening-port command again.
9. Optionally verify from another authorized host using Nmap.
10. Record before/after evidence.

What to Observe / Explain

- Disabling unused services reduces attack surface.
- Do not disable a service unless its purpose and dependencies are understood.

Report Format

Item	Record in Exam
Service	_____
Port	_____
Before	Running/Open
Action	Stopped/Disabled
After	Stopped/Closed
Verification method	_____

Result/Conclusion: Unnecessary network services were restricted and the reduced listening surface was verified.

SHEET 12

Q1. Perform a basic security audit of a system and document at least five security configuration improvements. [15M]

Aim: To perform a basic security audit of a system and document at least five configuration improvements.

Tools/Requirements: System settings, Firewall, Update status, Account/service inspection tools

Step-by-Step Procedure

1. Record system name, OS and role.
2. Check whether security updates are current.
3. Check that the host firewall is enabled and rules are appropriate.
4. Review user accounts and remove/disable unused accounts if authorized.
5. Review password policy for sufficient length and complexity.
6. List listening ports/services and identify unnecessary ones.
7. Check antivirus/endpoint protection status if present.
8. Review file/share permissions for excessive access.
9. Check remote-access services and ensure only required protocols are enabled.
10. Document at least five improvements with priority and reason.

What to Observe / Explain

- An audit compares current configuration against expected secure practice.
- Findings should be factual and tied to evidence from the system.

Report Format

Item	Record in Exam
1	Enable/verify firewall - reason/evidence: _____
2	Apply pending updates - _____
3	Strengthen password policy - _____
4	Disable unnecessary service - _____
5	Review unused accounts/permissions - _____

Result/Conclusion: A basic security audit was completed and at least five configuration improvements were documented.

Q2. Perform a vulnerability scan on an authorized lab system and classify the identified findings according to severity. [15M]

Aim: To perform a vulnerability scan on an authorized lab system and classify findings by severity.

Tools/Requirements: Authorized vulnerability scanner such as Greenbone/OpenVAS or Nessus, Authorized lab target

Step-by-Step Procedure

1. Confirm the target IP and written/lab authorization.
2. Open the approved vulnerability scanner.
3. Create or select a scan target using the authorized IP.
4. Choose a basic/non-destructive scan profile as instructed.
5. Start the scan and wait for completion.
6. Review each finding title and affected port/service.
7. Record scanner-assigned severity such as Critical, High, Medium, Low or Informational.
8. Record supporting evidence such as detected version or configuration issue.
9. Do not treat every scanner result as proven; note possible false positives.
10. Export or summarize the findings in a table.

What to Observe / Explain

- Severity generally combines likelihood and impact, but the scanner's score is not the whole business risk.
- Validation and asset context are important before remediation decisions.

Report Format

Item	Record in Exam
Finding	_____
Affected service/port	_____
Severity	Critical/High/Medium/Low/Info
Evidence	_____

Recommended action	
--------------------	--

Result/Conclusion: The authorized lab host was scanned and findings were classified according to the scanner's severity levels.

SHEET 13

Q1. Create a Report on vulnerability-scan findings and recommend suitable remediation steps for each finding. [15M]

Aim: To prepare a vulnerability-scan report and recommend remediation for each finding.

Tools/Requirements: Completed vulnerability scan results

Step-by-Step Procedure

1. Write the report title, date and authorized target.
2. Mention the scanner/tool and scan profile used.
3. Provide an executive summary of the number of findings by severity.
4. For each finding, write its title, severity and affected host/service.
5. Include concise evidence from the scanner output.
6. Explain the possible impact in simple terms.
7. Recommend a specific remediation such as patching, disabling a service, changing a configuration, restricting firewall access or updating TLS settings.
8. Assign a remediation priority, normally addressing confirmed Critical/High issues first.
9. Mention that findings should be retested after remediation.
10. End with an overall conclusion.

What to Observe / Explain

- Recommendations should directly address the cause of the finding.
- Do not recommend exploitation as verification in a normal practical report.

Report Format

Item	Record in Exam
Finding 1	Severity: __ Evidence: __ Remediation: __
Finding 2	Severity: __ Evidence: __ Remediation: __
Finding 3	Severity: __ Evidence: __ Remediation: __

Result/Conclusion: A clear vulnerability report was prepared with evidence, severity and suitable remediation for each finding.

Q2. Prepare a security assessment report containing the target, tools used, methodology, findings, evidence, risk level, and recommended solutions. [15M]

Aim: To prepare a complete security assessment report containing target, tools, methodology, findings, evidence, risk and recommended solutions.

Tools/Requirements: Assessment notes, scan/capture evidence

Step-by-Step Procedure

1. Create a title and scope section identifying only the authorized target.
2. Add target details: IP/hostname, OS or application if known, date and environment.
3. List all tools used and their purpose.
4. Write the methodology in order, e.g. configuration review, port/service discovery, traffic analysis and vulnerability scanning.
5. For each finding, give a unique ID and descriptive title.
6. Attach evidence such as command output, packet number, scan result or screenshot reference.
7. Assign a risk level and briefly justify it.
8. State the likely security impact.
9. Give a practical remediation recommendation.
10. Finish with a summary, limitations and retest recommendation.

What to Observe / Explain

- A good assessment report separates facts/evidence from interpretation.
- Only activities performed within scope should be documented.

Report Format

Item	Record in Exam
Scope/Target	_____
Tools	_____
Methodology	_____
Finding ID/Title	_____

Evidence	_____
Risk	_____
Remediation	_____

Result/Conclusion: A structured security assessment report was prepared with all required technical and risk information.

SHEET 14

Q1. Configure two systems in a small LAN, verify their IP configuration, and demonstrate successful connectivity. [15M]

Aim: To configure two systems in a small LAN, verify their IP settings and demonstrate successful connectivity.

Tools/Requirements: Two systems/VMs, LAN, ipconfig/ip addr, ping

Step-by-Step Procedure

1. Connect both systems to the same LAN.
2. Assign addresses in one subnet, e.g. A = 192.168.20.10/24 and B = 192.168.20.20/24.
3. Verify the settings using `ipconfig` or `ip addr`.
4. Confirm that both have the same subnet mask/prefix.
5. Check link/adaptor status.
6. Ping B from A.
7. Ping A from B.
8. Record packets sent, received and loss.
9. If ping fails, verify firewall and addressing.
10. Take evidence of IP configuration and successful ping.

What to Observe / Explain

- Same subnet + correct connectivity should produce ICMP replies.
- Bidirectional testing is useful because host firewalls may differ.

Report Format

Item	Record in Exam
System A	_____
System B	_____
Mask/prefix	_____
A to B ping	Success/Fail
B to A ping	Success/Fail

Result/Conclusion: The two-system LAN was configured, IP settings were verified, and successful connectivity was demonstrated.

Q2. Use ping and traceroute/tracert to verify connectivity and identify the route to a destination. [15M]

Aim: To use ping and traceroute/tracert together to verify reachability and identify the route to a destination.

Tools/Requirements: ping, tracert/traceroute

Step-by-Step Procedure

1. Select an authorized destination.
2. Run `ping <destination>` and record replies, loss and average RTT.
3. Run `tracert <destination>` on Windows or `traceroute <destination>` on Linux.
4. Record the first hop, which is commonly the local gateway.
5. Record the intermediate hops and the final destination.
6. Note any `\*` responses without assuming the route is broken.
7. Compare ping latency with hop delays.
8. If ping fails but traceroute shows some hops, identify where responses stop.
9. Save both outputs.
10. Write a combined interpretation.

What to Observe / Explain

- Ping answers 'is it reachable and how long does it take?'; traceroute answers 'through which hops does traffic travel?'.
- Different devices may block one diagnostic method while normal traffic still works.

Report Format

Item	Record in Exam
Destination	_____
Ping packet loss	_____
Average RTT	_____
Total hops	_____

Final hop reached	Yes/No
-------------------	--------

Result/Conclusion: Ping verified connectivity while traceroute/tracert showed the route followed to the destination.

SHEET 15

Q1. Perform an Nmap scan on an authorized lab host and record all discovered open ports. [15M]

Aim: To scan an authorized lab host with Nmap and record all discovered open ports.

Tools/Requirements: Nmap, Authorized target

Step-by-Step Procedure

1. Confirm the authorized target IP.
2. Run a normal scan: ``nmap <target>``.
3. If the practical specifically requires all TCP ports, run ``nmap -p- <target>``.
4. Wait for the scan to finish.
5. Record every port in state ``open``.
6. Record the protocol, normally TCP for this scan.
7. Record the service label reported by Nmap.
8. Do not include closed or filtered ports in the open-port list.
9. Save output with ``-oN open-ports.txt`` if required.
10. Count the total discovered open ports.

What to Observe / Explain

- A full TCP port scan checks ports 1-65535 and therefore may take longer than a default scan.
- Open ports represent services accepting connections.

Report Format

Item	Record in Exam
Target	_____
Open port 1	_____
Open port 2	_____
Open port 3	_____
Total open ports	_____

Result/Conclusion: All open TCP ports discovered on the authorized lab host were recorded.

Q2. Identify the services associated with the discovered ports and analyze the security significance of the results. [15M]

Aim: To identify services associated with discovered ports and explain their security significance.

Tools/Requirements: Nmap ``-sV``, Results from Q1

Step-by-Step Procedure

1. Use the open-port list from Q1.
2. Run ``nmap -sV <target>`` or limit probing to known ports using ``-p <ports>``.
3. Record service and version for each open port.
4. Compare each service with the host's expected role.
5. Identify unnecessary or unexpected services as increased attack surface.
6. Note whether services transmit clear text, e.g. legacy Telnet/FTP, if actually present.
7. Check whether a service version appears old only as an observation; do not declare it vulnerable without supporting evidence.
8. Recommend disabling unnecessary services, patching required services and restricting access with a firewall.
9. Prioritize exposed administrative services.
10. Prepare a security significance table.

What to Observe / Explain

- Security significance depends on whether the service is necessary, patched, securely configured and reachable by untrusted networks.
- Port number alone does not prove vulnerability.

Report Format

Item	Record in Exam
Port/service	_____
Version	_____
Expected?	Yes/No
Security concern	_____
Recommendation	_____

Result/Conclusion: The services behind the discovered ports were identified and their security significance was assessed.

SHEET 16

Q1. Capture traffic generated by a ping operation in Wireshark and identify the ICMP request and reply packets. [15M]

Aim: To capture ping traffic in Wireshark and identify ICMP Echo Request and Echo Reply packets.

Tools/Requirements: Wireshark, ping

Step-by-Step Procedure

1. Start Wireshark on the correct interface.
2. Start capture.
3. Run a ping to an authorized host.
4. Stop the capture.
5. Apply filter `icmp`.
6. Locate the Echo Request.
7. Record source, destination, type, code, identifier and sequence number if visible.
8. Locate the matching Echo Reply.
9. Verify reversed source/destination addresses and matching sequence number.
10. Record the time difference between request and reply if required.

What to Observe / Explain

- Echo Request/Reply form a pair; repeated pairs correspond to each ping probe.
- Missing replies may indicate packet loss or filtering.

Report Format

Item	Record in Exam
Request packet no.	_____
Reply packet no.	_____
Request src/dst	_____
Reply src/dst	_____
Sequence	_____
Result	Reply received

Result/Conclusion: The ping-generated ICMP request and reply packets were captured and identified.

Q2. Capture DNS traffic and identify the DNS query and corresponding response. [15M]

Aim: To capture DNS traffic and identify a DNS query and its corresponding response.

Tools/Requirements: Wireshark, nslookup/dig/browser

Step-by-Step Procedure

1. Start packet capture.
2. Generate a DNS lookup.
3. Stop capture.
4. Filter with `dns`.
5. Choose a query packet and note its transaction ID.
6. Record client IP, DNS server IP, query name and record type.
7. Find the response with the same transaction ID.
8. Record response code and answer records.
9. Check that source/destination are reversed.
10. Record packet numbers for evidence.

What to Observe / Explain

- Matching transaction IDs associate a response with its query.
- The response may contain one or more A/AAAA/CNAME records or an error code.

Report Format

Item	Record in Exam
Query packet	_____
Response packet	_____
Query name/type	_____
DNS server	_____
Answer	_____
Response code	_____

Result/Conclusion: The DNS query and matching response were captured and documented.

SHEET 17

Q1. Use Wireshark to analyze a sample network capture and identify at least three protocols. [15M]

Aim: To analyze a network capture with Wireshark and identify at least three protocols.

Tools/Requirements: Wireshark, Provided sample capture

Step-by-Step Procedure

1. Open the `.pcap`/`.pcapng` file.
2. Review the Protocol column.
3. Open Statistics > Protocol Hierarchy to see protocol distribution.
4. Select Protocol 1 and inspect a representative packet.
5. Repeat for Protocol 2 and Protocol 3.
6. For each protocol, record source/destination examples and its purpose.
7. Use display filters to isolate each protocol.
8. Note the transport protocol/port where relevant.
9. Record packet numbers as evidence.
10. Summarize how the protocols work together.

What to Observe / Explain

- Examples may include ARP, DNS, ICMP, TCP, UDP, HTTP, TLS and DHCP depending on the capture.
- Only report protocols actually present.

Report Format

Item	Record in Exam
Protocol 1	_____ / Packet: _____ / Purpose: _____
Protocol 2	_____ / Packet: _____ / Purpose: _____
Protocol 3	_____ / Packet: _____ / Purpose: _____

Result/Conclusion: At least three protocols present in the sample capture were identified and explained using packet evidence.

Q2. Identify any unusual or suspicious communication in the capture and provide evidence from the packet details. [15M]

Aim: To identify unusual or suspicious communication in a packet capture and support the observation with packet details.

Tools/Requirements: Wireshark, Sample capture

Step-by-Step Procedure

1. Review endpoints and conversations to understand normal communication.
2. Check for one host making connections to many ports/hosts in a short time.
3. Check for repeated TCP SYN packets without successful handshakes.
4. Check for repeated DNS queries, unusual domain names or unexpected destinations.
5. Check for high-volume or periodic traffic inconsistent with the host's normal role.
6. Apply a focused filter for the suspicious source/destination or protocol.
7. Select representative packets.
8. Record packet number, time, source, destination, protocol, ports and relevant flags/details.
9. Explain why the pattern is unusual compared with the rest of the capture.
10. Avoid claiming an attack if the evidence only shows unusual behavior.

What to Observe / Explain

- Evidence should be reproducible from packet numbers and filters.
- Suspicious traffic can still have a legitimate cause, so the conclusion should reflect uncertainty.

Report Format

Item	Record in Exam
Pattern	_____
Packet numbers	_____
Source -> Destination	_____
Protocol/port	_____
Evidence	_____
Assessment	Unusual/Suspicious/Normal explanation

Result/Conclusion: Unusual communication was identified and supported with packet-level evidence.

SHEET 18

Q1. Configure Burp Suite to intercept traffic from an authorized web application and capture an HTTP request. [15M]

Aim: To configure Burp Suite to intercept an authorized web application's traffic and capture an HTTP request.

Tools/Requirements: Burp Suite, Browser, Authorized lab app

Step-by-Step Procedure

1. Start Burp and confirm Proxy listener 127.0.0.1:8080.
2. Use Burp's browser or configure the test browser proxy.
3. Open Proxy > Intercept and turn interception ON.
4. Browse to the authorized application.
5. Capture the request.
6. Record method, path, Host and key headers.
7. Forward the request.
8. Confirm it appears in HTTP history.
9. Save/screenshot the request as evidence.
10. Restore browser proxy settings after the lab if manually changed.

What to Observe / Explain

- The captured request represents the browser-to-server HTTP message before it is forwarded.
- Use only the authorized test application.

Report Format

Item	Record in Exam
Listener	127.0.0.1:8080
URL	_____
Method	_____
Host	_____
Captured	Yes/No

Result/Conclusion: Burp was configured successfully and an authorized HTTP request was intercepted and recorded.

Q2. Modify and resend a safe test request in the authorized lab and identify the request headers and parameters. [15M]

Aim: To safely modify and resend an authorized lab request and identify request headers and parameters.

Tools/Requirements: Burp Suite Repeater, Authorized lab request

Step-by-Step Procedure

1. Capture a normal request and send it to Repeater using `Send to Repeater`.
2. Open the Repeater tab.
3. Identify the request line, Host and other headers.
4. Identify URL, body or cookie parameters.
5. Change only a harmless test value, e.g. a search term or non-sensitive display parameter.
6. Click Send.
7. Observe the response status, length and visible response content.
8. Compare the response with the original.
9. Restore the original value if needed and resend to confirm behavior.
10. Document the changed parameter and result; do not attempt destructive or unauthorized actions.

What to Observe / Explain

- Repeater is useful for manually replaying HTTP requests during authorized testing.
- A changed response does not by itself prove a vulnerability.

Report Format

Item	Record in Exam
Method/path	_____
Header examples	Host: __; User-Agent: __; Cookie: __
Parameter changed	_____
Original value	_____
Test value	_____

Response status/result	
------------------------	--

Result/Conclusion: A safe lab request was modified and resent, and its headers, parameters and response were documented.

SHEET 19

Q1. Run Nikto against an authorized test web server and record the important findings. [15M]

Aim: To run Nikto against an authorized test web server and record important findings.

Tools/Requirements: Nikto, Authorized web server

Step-by-Step Procedure

1. Confirm the target URL and port.
2. Run `nikto -h http://<target>`.
3. Use `-p <port>` if required.
4. Observe the web server banner/technology.
5. Record missing security headers reported by Nikto.
6. Record potentially interesting files, default files or server configuration issues.
7. Record any outdated server/component notice exactly as reported.
8. Save output to a file if required.
9. Do not assume every item is exploitable.
10. Prepare a prioritized findings table.

What to Observe / Explain

- Nikto reports many configuration and known-file checks.
- Important findings are those that increase exposure, reveal sensitive information or indicate insecure/outdated configuration.

Report Format

Item	Record in Exam
Target	_____
Finding 1	_____
Finding 2	_____
Finding 3	_____
Evidence	_____

Result/Conclusion: Nikto was run against the authorized lab server and the important findings were recorded.

Q2. Classify the findings as configuration issues or potential vulnerabilities and suggest suitable remediation . [15M]

Aim: To classify Nikto findings as configuration issues or potential vulnerabilities and recommend suitable remediation.

Tools/Requirements: Nikto output from Q1

Step-by-Step Procedure

1. Read each finding and determine what it describes.
2. Classify missing headers, directory listing, default files or information disclosure settings as configuration issues when appropriate.
3. Classify reports tied to known vulnerable/outdated components as potential vulnerabilities until independently verified.
4. Record the affected component or URL.
5. Assign a practical priority based on exposure and potential impact.
6. Recommend secure configuration for configuration issues.
7. Recommend patching/upgrading for outdated components.
8. Recommend removing unnecessary default/test content.
9. Recommend restricting access where a service/page should not be public.
10. Plan a rescan after remediation.

What to Observe / Explain

- Classification must match the evidence; scanner text alone may not confirm exploitability.
- Remediation should be specific and testable.

Report Format

Item	Record in Exam
Finding	_____
Class	Configuration / Potential vulnerability
Priority	High/Medium/Low

Result/Conclusion: The scan results were classified and practical remediation steps were recommended for each issue.

SHEET 20

Q1. Configure a basic host firewall to block an unnecessary port while allowing required traffic. [15M]

Aim: To configure a host firewall that blocks an unnecessary port while allowing required traffic.

Tools/Requirements: Linux UFW or Windows Defender Firewall, Two authorized lab systems for testing

Step-by-Step Procedure

1. Identify one required service and one unnecessary test port.
2. Check current firewall status.
3. On UFW, use `sudo ufw default deny incoming` and allow required outbound according to lab policy.
4. Allow the required service, e.g. `sudo ufw allow 22/tcp`.
5. Block the unnecessary port, e.g. `sudo ufw deny 23/tcp`.
6. Enable/reload the firewall if required.
7. Check `sudo ufw status numbered`.
8. Verify that the required service still works.
9. Verify that connection to the blocked port does not succeed.
10. Record before/after rules and results.

What to Observe / Explain

- Choose ports appropriate to the actual lab; do not block the service you are using for remote administration.
- The same logic can be implemented with Windows inbound rules.

Report Format

Item	Record in Exam
Allowed port/service	_____
Blocked port/service	_____
Firewall status	_____
Required traffic test	Pass/Fail
Blocked traffic test	Blocked/Not blocked

Result/Conclusion: The firewall was configured to permit required traffic and block an unnecessary port.

Q2. Verify the firewall rule by testing the permitted and blocked connectivity. [15M]

Aim: To verify the firewall by testing both permitted and blocked connectivity.

Tools/Requirements: ping, browser, SSH/Telnet/nc or Nmap as appropriate, Authorized test systems

Step-by-Step Procedure

1. Note the firewall rules created in Q1.
2. From another authorized system, test the allowed service.
3. Record successful connection or Nmap state for the allowed port.
4. Test the blocked port.
5. Record timeout/connection failure or a filtered/blocked result as appropriate.
6. Repeat after checking that the target service itself is running, so a closed service is not confused with a firewall block.
7. Use `nmap -p <allowed>,<blocked> <target>` if permitted to compare states.
8. Check local firewall logs if enabled.
9. Record the test commands and outputs.
10. Conclude whether the rules behaved as intended.

What to Observe / Explain

- A good test distinguishes 'service not running' from 'firewall blocking'.
- Results may appear filtered or time out depending on firewall behavior.

Report Format

Item	Record in Exam
Allowed port	_____ / test result: _____
Blocked port	_____ / test result: _____
Target service running?	Yes/No
Rule verified	Yes/No

Result/Conclusion: Testing confirmed whether the firewall correctly permitted required connectivity and blocked the unnecessary port.

SHEET 21

Q1. Configure a password policy with suitable length and complexity requirements. [15M]

Aim: To configure a password policy with suitable minimum length and complexity requirements.

Tools/Requirements: Local Security Policy / equivalent OS policy

Step-by-Step Procedure

1. Open the system's password-policy settings.
2. Set a minimum password length appropriate to the lab, e.g. 8-12 characters.
3. Enable password complexity requirements.
4. Set password history if instructed so recent passwords cannot be immediately reused.
5. Set minimum/maximum password age if part of the exercise.
6. Apply the policy.
7. Document each configured value.
8. Create/use a non-privileged test account for verification.
9. Attempt to change the password to a simple value.
10. Record whether the policy rejects it.

What to Observe / Explain

- Length is one of the strongest basic controls; complexity rules should be combined with protection against reuse and guessing.
- Use organization policy values in real environments.

Report Format

Item	Record in Exam
Minimum length	_____
Complexity	Enabled
History	_____
Max age	_____
Policy applied	Yes/No

Result/Conclusion: A password policy with suitable length and complexity controls was configured successfully.

Q2. Create a report to test the password policy using sample passwords and identify which passwords are accepted and which are rejected [15M]

Aim: To test the configured password policy with sample passwords and report which are accepted or rejected.

Tools/Requirements: Test account, Configured password policy

Step-by-Step Procedure

1. Write down the exact policy from Q1.
2. Prepare several sample passwords designed to test different rules.
3. Test a password shorter than the minimum length.
4. Test a long but simple password if complexity is enabled.
5. Test a password that includes required character categories and sufficient length.
6. Avoid using real personal passwords in the report.
7. Record only sample/test passwords.
8. For each attempt, record Accepted or Rejected.
9. Explain which rule caused each rejection.
10. Conclude whether enforcement matches the configured policy.

What to Observe / Explain

- Examples should be fictional. Do not expose real credentials.
- If a password that should fail is accepted, re-check whether the policy has actually applied to the test account/system.

Report Format

Item	Record in Exam
Sample: `abc123`	Expected: Reject Actual: _____ Reason: short/simple
Sample: `password123`	Expected: _____ Actual: _____ Reason: _____
Sample: `Lab@2026Pass`	Expected: Accept Actual: _____ Reason: meets policy

Result/Conclusion: The password policy was tested with safe sample passwords and acceptance/rejection results were documented.

SHEET 22

Q1. Perform a basic vulnerability scan on an authorized lab system. [15M]

Aim: To perform a basic vulnerability scan on an authorized lab system.

Tools/Requirements: Greenbone/OpenVAS, Nessus or instructor-approved scanner, Authorized lab target

Step-by-Step Procedure

1. Confirm scan authorization and target IP.
2. Open the vulnerability scanner.
3. Create a target entry.
4. Select a basic safe scan profile.
5. Start the scan.
6. Monitor progress until completion.
7. Review discovered services and vulnerability findings.
8. Record finding title, severity, affected port/service and evidence.
9. Export or save the report if required.
10. Do not perform exploit actions; this practical is for detection and reporting.

What to Observe / Explain

- A vulnerability scanner compares observed services/configuration with security checks and known issues.
- Results need validation because false positives/negatives are possible.

Report Format

Item	Record in Exam
Target	_____
Scanner	_____
Scan profile	_____
Critical/High	_____
Medium	_____
Low/Info	_____

Result/Conclusion: A basic authorized vulnerability scan was completed and the results were recorded.

Q2. Prepare a table of identified vulnerabilities with severity, affected service, and recommended remediation. [15M]

Aim: To prepare a table of vulnerabilities including severity, affected service and recommended remediation.

Tools/Requirements: Vulnerability scan result

Step-by-Step Procedure

1. Sort or review scan findings by severity.
2. Select each relevant finding.
3. Copy the exact finding title.
4. Record the affected host/port/service.
5. Record the scanner's severity.
6. Summarize the evidence in one line.
7. Write a remediation action that addresses the cause.
8. Use patch/update for outdated software findings.
9. Use configuration hardening or firewall restriction for unnecessary exposure.
10. Prioritize Critical/High confirmed issues and note that the system should be rescanned after fixes.

What to Observe / Explain

- A table makes remediation tracking easier.
- Severity should not be changed without justification; if you adjust priority, explain the asset context.

Report Format

Item	Record in Exam
Finding	Severity Service Remediation
_____	_____ _____ _____
_____	_____ _____ _____
_____	_____ _____ _____

Result/Conclusion: The vulnerability findings were organized with severity, affected service and suitable remediation.

SHEET 23

Q1. Prepare a complete security assessment report based on the vulnerability-scan results. [15M]

Aim: To prepare a complete security assessment report from vulnerability-scan results.

Tools/Requirements: Completed scan results, Evidence/screenshots

Step-by-Step Procedure

1. Create a report title and date.
2. Define the authorized scope/target.
3. Add an executive summary describing overall security posture in simple terms.
4. List the tools and scan profile used.
5. Explain the assessment methodology.
6. Summarize findings by severity.
7. Write each finding with evidence, affected service and impact.
8. Assign/retain a risk level.
9. Recommend remediation and priority.
10. Add limitations and a retest recommendation.

What to Observe / Explain

- A complete report should be understandable to both technical and non-technical readers.
- Evidence must come from the actual assessment.

Report Format

Item	Record in Exam
Report section	Content
Scope	_____
Tools/Method	_____
Findings summary	_____
Top risk	_____
Overall recommendation	_____

Result/Conclusion: A complete security assessment report was prepared from the authorized vulnerability-scan results.

Q2. Include target details, tools, methodology, findings, evidence, risk level, and remediation recommendations in the report. [15M]

Aim: To include target details, tools, methodology, findings, evidence, risk level and remediation recommendations in the security report.

Tools/Requirements: Assessment data from Q1

Step-by-Step Procedure

1. Target details: write IP/hostname, environment and authorization scope.
2. Tools: list scanner and supporting tools with purpose.
3. Methodology: write the sequence of steps actually performed.
4. Findings: assign IDs such as F-01, F-02 and clear titles.
5. Evidence: include exact scan output, screenshot reference, port/version or packet detail.
6. Risk level: Critical/High/Medium/Low/Info with a short justification.
7. Impact: explain what could happen if the issue is real and reachable.
8. Remediation: give a specific fix.
9. Verification: state how to confirm the fix, usually rescan/retest.
10. Conclusion: summarize the main risks and priorities.

What to Observe / Explain

- Do not include unsupported claims or fabricated evidence.
- Risk should be tied to exposure and impact, not just scanner wording.

Report Format

Item	Record in Exam
Finding ID	F-_____
Target/service	_____
Evidence	_____

Risk	_____
Remediation	_____
Retest	_____

Result/Conclusion: All required report elements were documented in a structured security assessment format.

SHEET 24

Q1. Set up a small authorized lab network and document its topology, IP addresses, and connectivity test results. [15M]

Aim: To set up an authorized lab network and document topology, IP addresses and connectivity results.

Tools/Requirements: Two or more lab systems/VMs, Switch/virtual network, ping

Step-by-Step Procedure

1. Identify the lab systems and how they are connected.
2. Draw a simple topology: System A - Switch/Virtual Network - System B, plus gateway if present.
3. Assign/record an IP address and subnet mask for each device.
4. Record default gateway/DNS if used.
5. Verify each system's configuration.
6. Check that systems intended to communicate are in the correct subnet.
7. Run ping tests between systems.
8. Record packets sent/received/lost.
9. If a gateway exists, ping it as an additional test.
10. Prepare a final topology and connectivity table.

What to Observe / Explain

- Topology documents the logical/physical relationship between devices.
- IP addressing should be consistent with the selected subnet.

Report Format

Item	Record in Exam
Device	IP / Mask / Role
System A	_____ / _____ / _____
System B	_____ / _____ / _____
Gateway	_____ / _____ / _____
Connectivity	A<->B: _____

Result/Conclusion: The authorized lab network was set up and documented with topology, addressing and successful connectivity tests.

Q2. Perform an Nmap scan of the lab network and summarize the active hosts, open ports, and detected services. [15M]

Aim: To scan the lab network with Nmap and summarize active hosts, open ports and detected services.

Tools/Requirements: Nmap, Authorized lab subnet

Step-by-Step Procedure

1. Identify the authorized subnet from Q1.
2. Discover active hosts using `nmap -sn <subnet>`.
3. Record active IP addresses.
4. For each authorized active host, run `nmap <ip>` to identify open ports.
5. Run `nmap -sV <ip>` when service detection is required.
6. Record port, state, service and version if shown.
7. Do not scan addresses outside the lab scope.
8. Compare services with each host's expected role.
9. Save outputs.
10. Prepare a host summary table.

What to Observe / Explain

- Network discovery gives a basic asset and exposure view.
- Not all active hosts respond to discovery, and version detection can be incomplete.

Report Format

Item	Record in Exam
Host	Open ports / Services
_____	_____
_____	_____
Total active hosts	_____

Result/Conclusion: The lab network was scanned and a summary of active hosts, open ports and detected services was prepared.

SHEET 25

Q1. Capture and analyze network traffic from the lab using Wireshark and identify normal and suspicious traffic patterns. [15M]

Aim: To capture and analyze lab network traffic and identify normal and suspicious traffic patterns.

Tools/Requirements: Wireshark, Authorized lab network

Step-by-Step Procedure

1. Start capture on the correct lab interface.
2. Generate normal baseline traffic: ARP, ping, DNS and approved web access.
3. Stop capture after a representative period.
4. Use Protocol Hierarchy, Endpoints and Conversations for an overview.
5. Identify normal patterns such as ARP requests, DNS query/response pairs, TCP handshakes and regular application traffic.
6. Look for unusual patterns such as repeated SYN attempts, many destination ports, repeated failed DNS lookups, unexpected protocols or unusual external destinations.
7. Apply filters to validate each pattern.
8. Record representative packet numbers.
9. Explain why each pattern is normal or suspicious in the lab context.
10. Save the capture and findings table.

What to Observe / Explain

- Normal vs suspicious depends on context and expected host behavior.
- Use observable evidence and avoid declaring malicious activity without sufficient proof.

Report Format

Item	Record in Exam
Normal pattern	_____ / evidence: packet(s) _____
Normal pattern 2	_____ / evidence: _____
Suspicious/unusual pattern	_____ / evidence: _____
Reason	_____

Result/Conclusion: The lab traffic was captured and analyzed, with normal and potentially suspicious patterns identified using packet evidence.

Q2. Perform a basic authorized web-security assessment using Burp Suite or Nikto and document the observations. [15M]

Aim: To perform a basic authorized web-security assessment using Burp Suite or Nikto and document observations.

Tools/Requirements: Burp Suite or Nikto, Authorized lab web app/server

Step-by-Step Procedure

1. Confirm the authorized URL/IP and choose the instructed tool.
2. If using Burp, configure the browser proxy and capture normal GET/POST requests.
3. Document request methods, parameters, cookies and security-related headers without exploiting the application.
4. If using Nikto, run `nikto -h http://<authorized-target>`.
5. Record server information, missing security headers, default files or configuration findings reported.
6. Classify observations as informational, configuration issue or potential vulnerability where justified.
7. Capture evidence such as request details or exact scan lines.
8. Recommend remediation such as secure headers, patching, disabling unnecessary content, server-side input validation or access restriction.
9. Do not perform destructive tests or scan outside scope.
10. Write a short assessment conclusion.

What to Observe / Explain

- Burp is useful for inspecting web requests manually; Nikto automates many web-server configuration checks.
- Findings should be documented with evidence and cautious wording.

Report Format

Item	Record in Exam
Tool used	Burp / Nikto
Target	_____

Observation 1	_____
Observation 2	_____
Risk/priority	_____
Recommendation	_____

Result/Conclusion: A basic authorized web-security assessment was completed and the observations and recommendations were documented.